

Controles ISO/IEC 27001:2022 aplicados al proyecto Renta Móvil Location

1) Organizacional (37 controles)

- Políticas y roles de seguridad: políticas de SI, roles y responsabilidades, segregación de funciones, gestión de proveedores/terceros.
 - Aplica: operaciones críticas (reservas, pagos, contratos) y uso de PSE requieren políticas, responsables y acuerdos.
- Gestión de riesgos y cambios: amenazas, disponibilidad del servicio, plan de continuidad, cambios en backend/app.
 - Aplica: dependencia de PSE, servidor estable, APIs externas, tolerancia a fallos.
- Inventario y clasificación de activos / protección de datos: datos personales, contratos, comprobantes.
 - Aplica: se manejan datos sensibles de clientes, contratos PDF y reportes.
- Seguridad con terceros (PSE/hosting).
 - Aplica: integración con PSE y proveedor de infraestructura requiere cláusulas de seguridad y SLA.
- Continuidad del negocio.
 - Aplica: metas de 99.5% de uptime, recuperación ≤ 10 min, no duplicar cobros.

2) De Personas (8 controles)

- Cribado/alta y baja de personal & confidencialidad.
 - Aplica: administradores/superadministrador con acceso privilegiado.
- Concienciación y formación en seguridad.
 - Aplica: manejo de datos personales y pagos PSE.
- Responsabilidades del usuario y teletrabajo (si aplica).
 - Aplica: operación del panel, reportes y soporte.
- Reporte de incidentes.
 - Aplica: registro de incidentes, reintentos y comunicación de fallos.

3) Físico (14 controles)

- Perímetros, control de acceso físico, protección ambiental, suministro eléctrico, resguardo de equipos.
 - Aplica: servidores/hosting y posibles equipos on-prem del proveedor.

- Eliminación segura de soportes.
 - Aplica: contratos/comprobantes descargados o respaldos requieren disposición segura.

4) Tecnológico (34 controles)

- Gestión de identidades y accesos (IAM).
 - Evidencia SRS: login, reglas de contraseña, bloqueo por intentos, roles diferenciados.
- Criptografía y protección de datos.
 - Evidencia SRS: HTTPS/TLS, contraseñas encriptadas, cifrado de datos sensibles.
- Seguridad en el ciclo de vida del software.
 - Evidencia SRS: validaciones, pruebas periódicas, documentación API.
- Seguridad de aplicaciones web y móviles.
 - Evidencia SRS: JWT con expiración, pagos PSE sin duplicidad, tiempos de respuesta, compatibilidad Android.
- Disponibilidad, resiliencia, tolerancia a fallos, monitorización.
 - Evidencia SRS: disponibilidad 99.5%, recuperación ≤ 5 min, reintentos, logs.
- Seguridad de interfaces y redes.
 - Evidencia SRS: API REST sobre HTTPS, validación JSON.
- Gestión de registros y monitoreo.
 - Evidencia SRS: auditoría de reservas/pagos, reportes.
- Gestión de vulnerabilidades.
 - Evidencia SRS: pruebas de seguridad, pentest.
- Seguridad con proveedores tecnológicos.
 - Evidencia SRS: dependencia PSE, hosting, backups.

Siguientes pasos

1. Política de SI y matriz RACI.
2. Matriz de riesgos con controles ISO mapeados.
3. Procedimiento de incidentes.
4. Acuerdos con terceros (PSE/hosting).
5. Hardening técnico: HTTPS, HSTS, JWT, privilegios mínimos, logs.

6. Pruebas de seguridad: análisis estático/dinámico y pentest.
7. Backups y restauración probados (RPO/RT0).
8. Formación del equipo en seguridad.